

S11/L4

Esercizio Funzionalità Malware

Traccia

La figura nella slide successiva mostra un estratto del codice di un malware. Identificate:

1. Il tipo di Malware in base alle chiamate di funzione utilizzate.
2. Evidenziate le chiamate di funzione principali aggiungendo una descrizione per ognuna di essa
3. Il metodo utilizzato dal Malware per ottenere la persistenza sul sistema operativo
4. BONUS: Effettuare anche un'analisi basso livello delle singole istruzioni

Figura 1:

.text: 00401010	push eax	
.text: 00401014	push ebx	
.text: 00401018	push ecx	
.text: 0040101C	push WH_Mouse	; hook to Mouse
.text: 0040101F	call SetWindowsHook()	
.text: 00401040	XOR ECX,ECX	
.text: 00401044	mov ecx, [EDI]	EDI = «path to startup_folder_system»
.text: 00401048	mov edx, [ESI]	ESI = path_to_Malware
.text: 0040104C	push ecx	; destination folder
.text: 0040104F	push edx	; file to be copied
.text: 00401054	call CopyFile();	

1. Tipo di Malware

Il malware utilizza la funzione `SetWindowsHook()`, ovvero una funzione che installa un metodo chiamato «hook» che ha il compito di monitorare degli eventi di una data periferica (in questo caso il mouse). Questo comportamento corrisponde a un malware di tipo **keylogger**.

2. Funzioni principali

Ci sono due funzioni usate dalla porzione di malware a disposizione:

- **SetWindowsHook()**: Questa è una funzione API di Windows utilizzata per installare un hook. Un hook è una funzione che può monitorare, intercettare o modificare i messaggi del sistema per determinati eventi come, in questo caso, l'input del mouse.
- **CopyFile()**: Questa istruzione chiama la funzione `CopyFile`, una API di Windows che copia un file da una destinazione a un'altra.

3. *Persistenza del Malware*

Analizziamo la porzione di codice nella figura sottostante.

.text: 00401044	mov ecx, [EDI]	EDI = «path to startup_folder_system»
.text: 00401048	mov edx, [ESI]	ESI = path_to_Malware
.text: 0040104C	push ecx	; destination folder
.text: 0040104F	push edx	; file to be copied
.text: 00401054	call CopyFile();	

Vediamo che il malware salva due path:

- **Cartella startup di Windows:** una cartella speciale del sistema operativo che viene controllata all'avvio del sistema, ed i programmi che sono al suo interno vengono eseguiti;
- **Posizione del Malware:** il percorso dell'eseguibile del Malware.

Successivamente, il malware chiama la funzione **CopyFile()** così da copiare il proprio file eseguibile all'interno della cartella startup di Windows. Questo porterà il Sistema Operativo ad eseguire il malware ad ogni suo avvio.

4. Analisi basso livello

Analizziamo il codice a basso livello:

- Push dei Registri

push eax, ebx, ecx: Salva i valori correnti dei registri eax, ebx e ecx sullo stack per salvare il loro stato.

push WH_Mouse: Salva il valore di «WH_Mouse» sullo stack. Questo valore rappresenta un codice che indica il tipo di hook da installare, in questo caso un hook per eventi del mouse.

- Chiamata a SetWindowsHook

call SetWindowsHook(): Questa funzione API di Windows consente di installare un hook per intercettare eventi di sistema, in questo caso eventi legati al mouse.

- Pulizia e Preparazione dei Registri

XOR ECX, ECX: Azzera il registro «ECX» impostandolo a 0.

mov ecx, [EDI]: Carica nel registro «ecx» l'indirizzo della stringa che rappresenta il percorso della cartella di avvio del sistema (startup folder).

mov edx, [ESI]: Carica nel registro «edx» l'indirizzo della stringa che rappresenta il percorso del file malware.

- Copia del Malware nella Cartella di Avvio

push ecx, push edx: Inserisce i percorsi (path) della cartella di avvio (ecx) e del file malware (edx) sullo stack, in ordine inverso, per passarli come argomenti alla funzione «CopyFile».

call CopyFile(): Chiama la funzione API «CopyFile», che copia un file da una sorgente (edx, il percorso del malware) a una destinazione (ecx, il percorso della cartella di avvio del sistema).